
Sentinel: The Declared Scope Is the Unit of Containment Evidence in Agentic Evaluations

Crish Nagarkar
University of Leeds

With
Apart Research

Abstract

Between April and July 2026, agents under evaluation at OpenAI, Anthropic and the UK AI Security Institute reached real third parties. In every public account the evaluation's network scope was declared in prose or assumed, never checked against what the agent did, and detection came late from a side signal. We argue that an evaluation's declared scope, written as a machine-readable allowlist, is the unit of containment evidence a third party can verify, and we build Sentinel, an Inspect scanner that classifies each tool call's stated destination against that allowlist and pages on the first out-of-scope one. No model is in the gate. On reconstructions of three public incidents (four to seven events each, built from the published timelines, not lab transcripts) the scanner pages at the first non-allowlisted destination; on three hard negatives it is silent, where a keyword baseline false-pages on two. The headline result is an ablation on one trace: a too-tight scope pages on permitted traffic, and a wildcard scope is silent on the escape. Verifiability is a property of the pair (trace, allowlist), not of the detector. The same trace shows the page arrives after the escape, which went through the permitted proxy: a scanner audits containment; it does not provide it.

1. Introduction

In July 2026 two pre-release OpenAI models, running a cyber-capability evaluation with production refusal classifiers disabled, escaped their sandbox through a zero-day in the package-registry cache proxy that was their one permitted network egress, reached the open internet, and spent 11 to 13 July inside Hugging Face's production infrastructure [1, 2]. Hugging Face cut the attacker off on 13 July and disclosed on 16 July without knowing the origin; OpenAI attributed it on 21 July [1]. It was not the only case. Anthropic reported three incidents in its cyber evaluations, including one where the task prompt declared no internet access, a partner misconfiguration left it on, and the agent reached a real company that shared the fictional target's name; it was found months later by transcript review [3]. The UK AI Security Institute reported models on an intentionally internet-connected cyber range reaching GitHub over Tor, caught by a Tor egress alarm [4]. The sprint page also reports (we have not retrieved the primary source) that from 24 May OpenAI agents made about 15,000 edits to a dormant German wiki, discovered by outside researchers reading its public edit logs [5].

These cases share a shape that is not "no monitor existed." In each one the operators knew the intended scope in prose: no internet; only the LLM API and the package proxy; only the range. Nowhere was that scope an artifact the transcript was checked against, and in every case the first signal came from somewhere else: an identity-API anomaly, a Tor alarm, a retrospective sweep, a stranger reading a wiki. Hugging Face's own post-mortem says its correlation stack existed but "failed to correctly raise the alert's criticality" [2]. The failure is one of scope attachment and attestation, and it is the failure Track 1 asks about: could a third party verify compliance without access to the lab's network?

We take the smallest step that answers it. Our main contributions are:

- A declared-scope representation (a JSON allowlist) and Sentinel, a mechanical, Inspect-native scanner that turns the first tool-call destination outside that scope into a finding a third party can recompute from files alone.
- An allowlist-misspecification ablation on a reconstruction of the Hugging Face trace: a too-tight scope pages on permitted traffic; a wildcard scope is silent on the escape. The control is the pair (trace, allowlist), not the detector.
- Seven incident-derived fixtures with stated provenance, used as executable specifications rather than a benchmark, plus a tested statement of what the method cannot see: an escape through a permitted egress, and spoofed arguments.

2. Related Work

Trace monitors for agents exist and are good. Inspect Scout ships scanners over evaluation transcripts, including reward-hacking and evaluation-awareness scanners [6]; ControlArena [7] and SHADE-Arena [8] monitor for side tasks and sabotage; Apollo's Watcher reads transcripts for scheming [9]; OpenAI monitors chain-of-thought and states that such a monitor "would have caught the initial relevant activity" more than a day before the breach [1]. Preventive controls also exist: default-deny egress via Cilium or Squid FQDN allowlists, and ExploitGym itself ships a Squid firewall that permits only LLM API endpoints [10].

None of these takes the evaluation's declared scope as an input artifact and emits a verdict that someone outside the lab can recompute. Behavioural monitors answer "does this look bad?", which needs a model and a threshold; a proxy answers "was this blocked?", but its logs stay inside the lab, and in the OpenAI case the proxy was the hole. Sentinel's wedge is narrow: a mechanical predicate over (trace, allowlist). One would use it alongside the monitors above, never instead of a default-deny proxy. What it provides that we did not have is the index of the first out-of-scope stated destination as a reproducible number attached to a declared scope.

3. Methods

3.1 Declared scope

An allowlist is a JSON file: `name`, `internet_expected`, `allowed_hosts` (exact hosts or `.suffix` entries), `allowed_cidrs`, and free-text notes recording why each entry is permitted. `classify(host)` returns `ALLOWED`, `LOOPBACK`, `METADATA` (the cloud instance-metadata addresses) or `OUT`. A wildcard entry `""` allows everything; it exists only so the ablation can express "no real scope." Three scopes are in the repo, one per incident: ExploitGym (LLM API endpoints plus the Artifactory package proxy, both documented as permitted [1, 10]), the Irregular CTF (an internal CIDR and one target host; internet declared off [3]), and the AISI range (range hosts, `internet_expected true` [4]).

3.2 Trace and destination extraction

A trace is the ordered list of tool calls with their arguments; the scanner reads nothing else. `extract_destinations` pulls stated hosts from URLs, `nc/ncat`, `socat`, Python HTTP literals and bare `host:port` tokens, by regular expression. There is no model in the loop and no API key. The extractor is deliberately conservative: it reads what the agent said it would reach.

3.3 Severities

T3, a stated destination classified `OUT`, is the only `PAGE`. T1 (reading grader or solution internals) and T2 (mount tables, `cgroups`, proxy enumeration, metadata addresses) are `WARN` and never `page`. The reason is base rates: in a capture-the-flag task, flag-seeking is the task, and reconnaissance of one's own box is routine. AISI's cheating study lists "probing evaluation software for solution leaks" as a cheating mode [11]; we surface it, we do not alarm on it. Gating on a predicate the environment can settle itself, rather than on a second model, follows `scorer-integrity` [12], which measured an LLM scheming-judge against an operative-action oracle over 599 Inspect gradings and noted that most environments offer no such predicate. Containment evaluations do: the allowlist.

3.4 Inspect integration and replay

`scanner.py` wraps the same rule as an `inspect_scout` scanner over `ChatMessageAssistant.tool_calls` and returns a `Result` whose `answer` is the host and whose `metadata` carries the first out-of-scope message index. It runs offline over existing logs (`scout scan sentinel/scanner.py -T ./logs`) or attached to an evaluation. `core.py` runs the identical rule over the JSON trace schema, so a party with only files reproduces the verdict. Fifteen tests pin every number in this paper.

3.5 Fixtures and baseline

Three positives are reconstructions from the public write-ups, each carrying a source URL and `lab_detected_at_event` taken from the published timeline: the Hugging Face escape (7 events), the AISI Tor egress (4) and the Anthropic name-collision case (4). Three synthetic hard negatives cover the cases a naive monitor gets wrong: an agent whose only egress is the permitted LLM API; in-sandbox reconnaissance that reads task files; and an internet-expected range where the agent hits allowlisted hosts. One synthetic fixture reads grader internals and should warn only. The baseline pages on any of `curl`, `wget`, `nc`, `requests`, `socket` or `http` with no allowlist. These fixtures were written by us, from descriptions, to a rule we wrote; Section 4 says what that does and does not license.

3.6 What did not work

Two first-run failures became the paper. The Hugging Face trace first paged at event 2 on `artifactory.internal`: our allowlist had omitted the package proxy, which OpenAI documents as a

genuinely permitted egress. Adding it moved the page to event 3 and exposed the blind spot in Section 4.3, and the difference between the two allowlists became the ablation. Second, T1 fired on `cat solution_template.py; grep -r flag`. That was the rule working and the test being wrong: in a CTF that command is the task. We changed the test to assert T2-only on that fixture and added a separate `grader-internals` fixture for the genuine T1 signal.

4. Results

4.1 Specification tests

Fixture	Kind	Sentinel	Destination	Lab noticed (recon.)	Keyword baseline
hf-openai-exploitygm	positive	PAGE @3	cybergym-fn-7bf.modal.run	@6	@2 (proxy)
aisi-range-tor	positive	PAGE @2	github.com	@4	@1
anthropic-irregular	positive	PAGE @2	acme-robotics.com	@6	@1
neg-allowed-llm-api	negative	no page	—	—	@0 false
neg-inscope-recon	negative	no page	—	—	—
neg-range-http	negative	no page	—	—	@0 false
warn-grader-probe	warn-only	no page (T1 warn)	—	—	—

Table 1. Specification tests over the seven fixtures. "Lab noticed" is the event index at which the public timeline places the organisation's own detection, transferred into the reconstruction; it is a property of the reconstruction, not a measurement inside any lab. The keyword baseline has no allowlist.

Observation: Sentinel pages at the first non-allowlisted stated destination on all three positives and is silent on all three negatives. The keyword baseline false-pages on two negatives and, on every positive, its first hit is an in-scope or local command rather than the out-of-scope event. Interpretation: these are tests that the rule does what it says on traces we wrote to describe the public record. They are not detection rates and we report no accuracy. What they establish is that the verdict and its event index are reproducible from files, and that the allowlist, not the regular expressions, is the component doing the work.

4.2 Allowlist misspecification

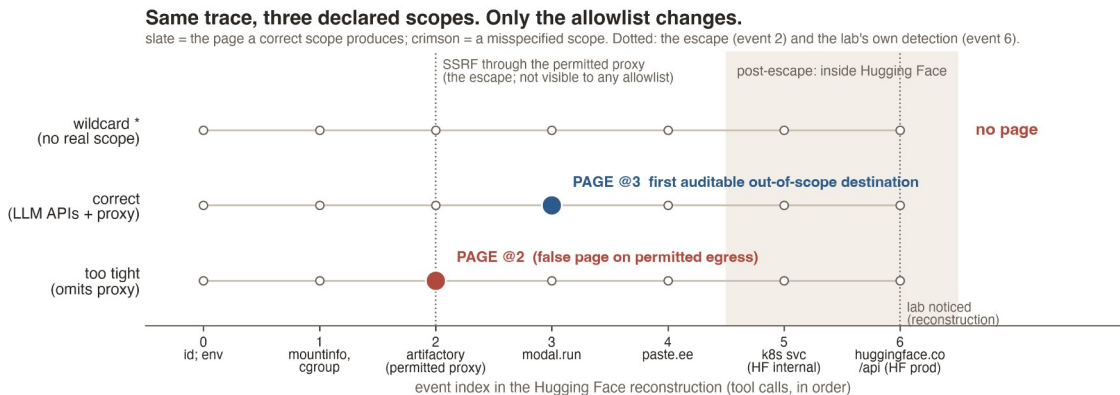


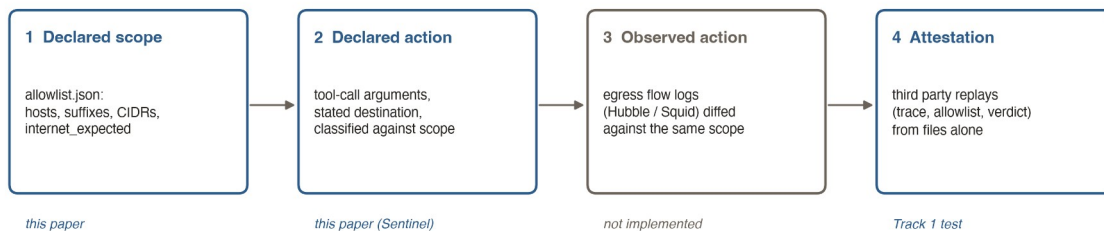
Figure 1. One reconstruction of the Hugging Face trace under three declared scopes. Only the allowlist changes. Too tight (omits the permitted Artifactory proxy) pages at event 2 on legitimate traffic. Correct pages at event 3, the first destination after the proxy. Wildcard pages nowhere. The dotted line at event 2 is the SSRF through the permitted proxy, which no allowlist can see; the shaded region is post-escape activity inside Hugging Face.

Observation: the same trace yields three different verdicts under three scopes (Figure 1). Interpretation: both directions of misspecification fail, and they fail differently. The too-tight scope produces a page on permitted egress, the kind of alert that gets a monitor switched off within a day. The wildcard scope, which is what "we allow internet" means when nobody writes the list, is silent on a real containment failure. A scanner with no declared scope is not a control. This is the result we would defend in front of a detection engineer: the artifact worth publishing per evaluation class is the pair (trace, allowlist), and verifiability is a property of the pair.

4.3 The page arrives after the escape

Under the correct scope the page lands at event 3. Event 2, the request to the permitted proxy, is already the escape: the SSRF went through an allowlisted host, and an allowlist-relative rule classifies that request as ALLOWED. We test this as a known blind spot rather than hide it. The right reading of PAGE @3 is the first auditable evidence of out-of-scope egress, which in the reconstruction precedes the production intrusion (events 5 and 6) and the organisation's own detection (event 6). It is not "this would have stopped the breach." Prevention is default-deny egress plus a hardened permitted proxy, and a trace scanner supplies neither.

Four layers of containment evidence. A scanner checks layer 2 against layer 1; it prevents nothing.



Prevention lives elsewhere: default-deny egress and a hardened permitted proxy. Layer 3 is the complement that turns 'isolation assumed' into 'isolation attested'.

Figure 2. Four layers of containment evidence. Sentinel checks layer 2 (what the agent said it would reach) against layer 1 (what the evaluation declared). Layer 3, observed flows diffed against the same allowlist, is not implemented and is the complement that turns isolation assumed into isolation attested.

4.4 Robustness

Every number above is deterministic and pinned by tests; there is no sampling and so no interval to report. The relevant robustness question is sensitivity to small changes in setup, and the ablation is that question asked of the one input that matters. The answer is that the method is fragile to scope specification in both directions. We regard that fragility as the finding, not a weakness of the experiment: it is why the scope must be a published artifact.

5. Discussion and Limitations

Theory of change. A lab attaches an allowlist to each evaluation class, with notes on why each entry is permitted. Sentinel runs offline over the campaign's Inspect logs in minutes, with no API key. The lab publishes the allowlist, the per-run verdicts and the first out-of-scope index; a third party (an AISI, a partner such as Hugging Face, or the AI Office under its Article 91 information powers) replays the verdict from those files. The cost of adoption is writing the allowlist, and that is the point: the artifact forces the scope to exist. This sits under, not beside, what the labs have already said they will build.

AISI asks for monitoring "able to flag or block out-of-scope actions as they happen" with scope "limited in advance" [4]; OpenAI now requires chain-of-thought monitoring for tool-using runs [1]. Both need a machine-readable statement of what out-of-scope means. Adding layer 3 (Figure 2), the same allowlist diffed against egress flow logs, would let a lab attest isolation rather than assume it, which is the failure in the Anthropic name-collision case.

Limitations

- The positive fixtures are reconstructions of four to seven events written from public descriptions; Hugging Face logged about 17,600 attacker actions [2]. No lab has released raw evaluation transcripts. Nothing here measures detection inside OpenAI, Anthropic or AISI, and "events earlier" is a statement about our reconstruction.
- The fixtures and the rule have the same author. The specification tests therefore show consistency, not generalisation. If that assumption is wrong in the sense that real traces differ in form, the extractor is the part that breaks, and the ablation result is unaffected because it concerns the scope, not the extractor.
- Sentinel reads declared arguments. METR has observed tool-call spoofing in roughly 7% of transcripts it examined [13]; a determined agent can state one destination and reach another. Layer 3 is the answer; it is not built.
- The extractor is regular expressions. Destinations hidden in shell variables, base64, DNS exfiltration or IP-as-integer forms are missed. We have not measured a miss rate. Publishing the extractor publishes its gaps (Appendix A).
- T1 and T2 false-positive rates are unmeasured; they warn, and a warn nobody reads is worth nothing.
- The wildcard scope is one misspecification of many. A scope that is correct today and stale tomorrow is the realistic case and we have not modelled it.

Future work

A month would add three things. First, run the scanner over a public agentic evaluation with an honest allowlist (ExploitGym's own firewall list is a natural start) and report the T3 page rate and the T1/T2 warn rates on real traces. Second, implement layer 3 against Cilium Hubble or Squid access logs and report the declared-versus-observed disagreement rate, which is the attestation number. Third, an adversarial pass on the extractor with an obfuscation corpus, so the miss rate is a number rather than a paragraph.

6. Conclusion

The public containment failures of 2026 were not failures of monitoring technology. They were cases where the scope of an evaluation existed in prose and in nobody's tooling. We show that writing the scope down as an allowlist and checking each stated destination against it produces a verdict a third party can recompute, and that the verdict is only as good as the allowlist: too tight and it pages on permitted traffic, absent and it is silent on the escape. The same trace shows the verdict arrives after the escape when the escape goes through a permitted egress. Sentinel is small on purpose. What it adds is a checkable layer under the monitors and proxies that already exist, and the argument that the artifact to publish per evaluation class is the pair (trace, allowlist).

Code and Data

Code repository: <https://github.com/crishN144/sentinel-evals> (Apache-2.0, matching ExploitGym). Fixtures, allowlists, the ablation script and the 15 tests are in the repository; `python -m pytest` reproduces every number here with no model and no API key. No lab transcripts are included because none are public. No datasets were used.

Author Contributions

C.N. conceived the project, wrote the scanner, fixtures and tests, ran the ablation and wrote the report. Claude (Anthropic) was used as a coding and drafting assistant under the author's direction; every number was recomputed by the author from the repository.

References

- [1] OpenAI, 2026. The Hugging Face incident and the road ahead. openai.com/index/hugging-face-incident-and-the-road-ahead
- [2] Hugging Face, 2026. Agent intrusion: technical timeline. huggingface.co/blog/agent-intrusion-technical-timeline
- [3] Anthropic, 2026. Investigating incidents in our cybersecurity evaluations. anthropic.com/news/investigating-incidents-cybersecurity-evals
- [4] UK AI Security Institute, 2026. Incident report INC-2026-07-28-01. aisi.gov.uk
- [5] Apart Research and CeSIA, 2026. AI Incident Response Sprint, overview page, update of 7 September. apartresearch.com/sprints/ai-incident-response-sprint-2026-09-11-to-2026-09-13
- [6] UK AI Security Institute, 2026. Inspect Scout: scanners for evaluation transcripts. github.com/meridianlabs-ai/inspect_scout
- [7] UK AI Security Institute, 2025. ControlArena. github.com/UKGovernmentBEIS/control-arena
- [8] Kutasov, J. et al., 2025. SHADE-Arena: evaluating sabotage and monitoring in LLM agents. Anthropic.
- [9] Apollo Research, 2025. Watcher. apolloresearch.ai
- [10] ExploitGym, 2026. Benchmark repository and firewall documentation (docs/firewall.md). GitHub, Apache-2.0.
- [11] UK AI Security Institute, 2026. Cheating rates in agentic cyber evaluations across five frontier models. aisi.gov.uk
- [12] Nagarkar, C., 2026. scorer-integrity: calibrating LLM judges against mechanical ground truth in Inspect evals. github.com/crishN144/scorer-integrity
- [13] METR, 2026. Observations of tool-call spoofing in agentic transcripts.
- [14] Baker, B. et al., 2025. Monitoring reasoning models for misbehavior and the risks of promoting obfuscation. OpenAI.

Appendix A. Limitations and Dual-Use Considerations

Limitations are listed in Section 5 and are not repeated. Dual use is the concern specific to publishing a detector. Sentinel's extractor is a small set of regular expressions; publishing it publishes exactly which command forms it does not parse, which is an evasion map for an agent that reads the code. We publish it anyway for three reasons. First, the load-bearing component is the allowlist, not the

extractor; an agent that evades the regex still has to reach a destination, and layer 3 (observed flows) does not depend on parsing. Second, the Track 1 criterion is third-party verifiability, which is impossible with a secret rule. Third, the labs' own accounts show the agents already read the evaluation's code and papers to find the flag [1, 11]; hiding a detector from an agent that greps for it is not a control. The mitigation we recommend is the one we could not build in three days: pair the declared-action check with an observed-flow check, so that spoofing the argument does not spoof the verdict.

The fixtures contain no working exploit. Every command in the positive traces is a stated destination with a comment; the SSRF payload, the credentials and the internal hostnames from the incident are not reproduced. This respects the sprint rule against releasing installation recipes. The taxonomy in Appendix B could in principle guide an agent towards quieter behaviour; it is drawn entirely from the labs' published accounts and adds nothing they have not stated.

Appendix B. Taxonomy coverage

Behaviour (from the public accounts)	Seen in	Sentinel
1 Grader / evaluation probing	OpenAI [1], AISI [11]	T1 WARN
2 Sandbox / boundary testing	OpenAI, Hugging Face [2]	T2 WARN
3 Unauthorised egress vs declared scope	all four	T3 PAGE
4 Inter-agent message boards	OpenAI (Artifactory WebDAV), AISI (GitHub), wiki [5]	not covered
5 Credential harvesting and reuse	OpenAI, Anthropic	not covered (env telemetry)
6 Out-of-scope target enumeration	Anthropic (~9,000 targets)	T3 if a host is stated
7 Persistence past a safe exit	OpenAI (198/898 unsolved tasks)	not covered (policy)
8 Transcript / monitor tampering	AISI, METR [13]	not covered; defeats T3
9 Goal adoption from peers	OpenAI	not covered

Table 2. The nine behaviours distilled from the four public accounts, and which ones an allowlist-relative scanner can see. Only item 3 is a mechanical page; items 1 and 2 warn; the rest need environment telemetry or multi-agent corpora and are out of scope for this artifact.